

Section 04



Industrial Security (Master)

Section 04 – Offensive ICS in Authorised Labs

Offensive ICS in Authorised Labs

Lecture Notes

Department of Computer Science

1 Ethics and Scope

2 The Lab

3 Tactics

4 Reporting

By the end of this section you will be able to

- Distinguish authorised testing, red-team exercises, and unauthorised access – legally and ethically.
- Build a contained lab in which destructive testing is safe.
- Apply standard ICS-attack techniques (reconnaissance, protocol abuse, logic injection) with full attribution.
- Produce findings that the asset owner can act on without re-doing the work.

1

Ethics and Scope

Section 04 – Offensive ICS in Authorised Labs

Authorised
penetration test

Authorised red team
(internal-blind)

Unauthorised access
(criminal)

Paper, not handshake

“Verbal” permission is no permission. A signed Rules of Engagement document with named approvers, scope, timing, kill-switch, and reporting path is the gating artefact for any engagement.

Source: NIST SP 800-115 Technical Guide to Information Security Testing; PTES Technical Guidelines.

- **Germany:** §202a / 202c StGB criminalise unauthorised access and *preparation tools*; commercial pentesting needs written authorisation.
- **EU CRA (2024/2847):** research safe-harbour for vulnerability disclosure under coordinated terms.
- **US CFAA & DMCA §1201:** authorisation contracts grant access; safe-harbour for security research since 2015 rulemaking.
- **ISO/IEC 29147 & 30111:** normative guidance for coordinated disclosure.

Caution

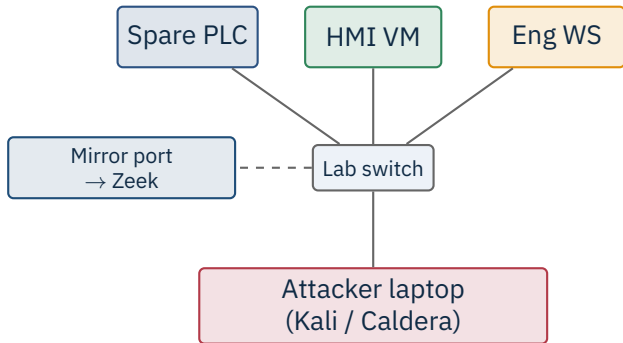
Cross-border engagements need both legal opinions. A US-headquartered firm testing a German plant follows the strictest applicable law.

Source: StGB §202a, §202c; Directive (EU) 2022/2555; Regulation (EU) 2024/2847; ISO/IEC 29147:2018, 30111:2019.

2

The Lab

Section 04 – Offensive ICS in Authorised Labs



Air-gapped, recorded

No Internet, no host bridge, full PCAP. Every action you take is later auditable to a wall-clock minute.

Tier	Examples	Best for
Pure software	OpenPLC, ScadaBR, open62541	teaching, basic protocol work
Mixed	Spare Siemens S7-1200, Modicon M580	realistic on-the-wire behaviour
Production-grade	Vendor demo kits, donated equipment	vendor-specific exploit research

Donations

Many vendors donate retired equipment to academic and CERT labs in exchange for confidentiality on findings. Always worth asking.

3

Tactics

Section 04 – Offensive ICS in Authorised Labs

- ARP / LLDP / CDP listening to enumerate devices.
- Passive Zeek capture for 24h to build a baseline.
- Vendor banners on web UIs (read-only HTTP GET / robots.txt).
- Project files on file shares (engineering WS, contractor laptops).

Caution

Active scans on the bench Nmap with `-max-rate` and only NSE scripts known safe for the target. Run once, capture, then decide if a deeper probe is worth the risk.

Source: ICS-CERT (CISA) recommended practices; Dragos ICS Knowledge Pack.

Modbus – write to coils / holding regs without auth

S7comm – start/stop CPU, upload OB, download poisoned OB

DNP3 – spoof control message, exploit unauthenticated read

GOOSE – spoof higher stNum to inject false trip

OPC UA – enumerate anonymous endpoints, abuse weak user policies

Source: MITRE ATT&CK for ICS, T0855/T0867/T0846/T0848/T0858.



Reversibility

Always take a verified backup of the original program first, and test the rollback before injecting. “Oops” on production hardware is career-ending.

Source: Lab pattern adapted from Klick, J., Lau, S. et al., “Internet-facing PLCs as a Network Backdoor”, BlackHat USA, 2015.

Metasploit (modbus, modicon_stux)

Caldera + ATT&CK ICS

Smod (Modbus framework)

plcscan, pymodbus, snap7

ISF

OpenVAS / Greenbone

Source: Tool repos: Rapid7 Metasploit; MITRE Caldera; theralfbrown/smod; dark-lbp/isf; Greenbone Networks.

4

Reporting

Section 04 – Offensive ICS in Authorised Labs

1. Executive summary – 1 page, plain language

2. Scope, ROE, attestations

3. Findings, each: title, CVSS-E, evidence, repro

4. Recommendations, sized this-quarter / this-year

5. Appendix: PCAPs, configs, raw logs

Reproducibility

A finding without a step-by-step repro is theatre. If the asset owner cannot reproduce it after a week, they will not trust the rest of the report.

- Listing CVEs without saying which versions are actually in the plant.
- Confusing “vulnerable” with “exploitable in this environment”.
- Recommendations without owners or timelines.
- Findings ranked by CVSS only, not by process-impact.
- Reusing screenshots between clients (legal disaster).

Caution

The asset owner's safety engineers should be able to read the report and say whether the test *could have* caused a process upset. If not, your scope was wrong.

★ Key Takeaway: Offensive ICS, responsibly

- Signed Rules of Engagement gate every action – no signature, no test.
- Build a contained lab; never fuzz or inject on production.
- Standard ICS-attack patterns (recon, protocol abuse, logic injection) cover most engagements.
- Report in plain language with reproducible evidence and prioritised recommendations.
- Cross-border work follows the strictest applicable law.

- NIST SP 800-115. *Technical Guide to Information Security Testing and Assessment*, 2008.
- PTES. *Penetration Testing Execution Standard*, technical guidelines.
- ISO/IEC 29147:2018. *Vulnerability disclosure*.
- ISO/IEC 30111:2019. *Vulnerability handling processes*.
- Klick, J., Lau, S., Marzin, D., Malchow, J.-O., Roth, V. “Internet-facing PLCs as a Network Backdoor”, BlackHat USA, 2015.
- MITRE. *ATT&CK for ICS*, knowledge base, current.
- MITRE. *Caldera* adversary emulation, with ICS plug-in.
- Rapid7. Metasploit Framework, modbus and ICS modules.
- Bodungen, C.E., Singer, B., Shbeeb, A., Hilt, S., Wilhoit, K. *Hacking Exposed: Industrial Control Systems*, McGraw-Hill, 2016.
- Dragos. *ICS Knowledge Pack* and *Year in Review* reports.
- OPC Foundation. *OPC UA Security Bulletin* archive.
- Forescout Vedere Labs. ICS vulnerability research outputs.

End of Section 04

Offensive ICS in Authorised Labs

Questions and discussion